Jonas Scharp (MyImmo)
Ludwig-Jahn-Straße 42 · 23611 Bad Schwartau
info@myimmoapp.de

Auftragsverarbeitungsvertrag

(AVV)

Vereinbarung nach Art. 28 Abs. 3 DSGVO

Stand: 10. Oktober 2026

zwischen

der Nutzerin / dem Nutzer des jeweiligen MyImmo-Kontos (Vermieter)
als Verantwortlichem

und

Jonas Scharp (MyImmo), Bad Schwartau
als Auftragsverarbeiter

> Entwurf zur anwaltlichen Prüfung. Dieses Dokument dient der rechtlichen Durchsicht und ist noch nicht final freigegeben. Keine Rechtsberatung.

1. Parteien, Gegenstand und Dauer

Verantwortlicher: die Nutzerin / der Nutzer des jeweiligen MyImmo-Kontos (Vermieter).

Auftragsverarbeiter: Jonas Scharp (MyImmo), Ludwig-Jahn-Straße 42, 23611 Bad Schwartau („Betreiber“).

Gegenstand ist die Bereitstellung der Web-Anwendung MyImmo zur Immobilien- und Mietverwaltung, in der der Verantwortliche personenbezogene Daten Dritter (insbesondere seiner Mieter und Mietinteressenten) speichert und verarbeitet. Die Vereinbarung gilt für die Dauer des Nutzungsverhältnisses und endet mit der Löschung des Kontos.

> Nicht Gegenstand dieser Fassung: Die treuhänderische Verwaltung fremder Immobilienbestände durch gewerbliche Hausverwaltungen (Mehrmandanten-Verwaltung) wird — vor ihrer produktiven Nutzung — durch eine gesonderte Ergänzung dieses Vertrags geregelt.

2. Art und Zweck der Verarbeitung

Hosting, Speicherung, Anzeige, Auswertung und Ausgabe (z. B. Abrechnungen, Briefe, Exporte) der vom Verantwortlichen erfassten Daten. Hinzu kommen — jeweils auf Veranlassung des Verantwortlichen:

- Mieterportal für die von ihm eingeladenen Mieter: Meldung von Zählerständen mit Foto-Beleg, Schadens- und sonstige Anliegen mit Foto-/Dokumentanhängen und Nachrichtenverlauf, Terminabstimmung, Einsicht in das eigene Mietkonto, Mitteilungen und Gebäude-Informationen sowie die Zustellung von Dokumenten (z. B. Nebenkostenabrechnung) an das verbundene Konto des Mieters mit Zeitpunkt von Zustellung, Abruf und Lesebestätigung. Nach dem Auszug bleibt der Zugang bis zum 31.12. des Folgejahres bestehen, danach endet er;
- Versand von E-Mails: Einladungen ins Mieterportal an die vom Verantwortlichen eingetragene Adresse des Mieters sowie inhaltslose Hinweis-E-Mails („es liegt etwas Neues bereit“) an die Adresse des jeweiligen Kontos; Briefe an Mieter (z. B. Zahlungserinnerungen) versendet der Betreiber nicht — sie erzeugt der Verantwortliche als PDF und verschickt sie selbst;
- Mietbewerbungen: Erfassung und Auswertung von Selbstauskünften von Mietinteressenten;
- Service-Partner: Abwicklung von Aufträgen mit vom Verantwortlichen beauftragten Hausmeistern und Dienstleistern (mit eigenem Zugang) einschließlich Fotos und Notizen zum Auftrag, Freigabe-Anträgen und der für Termin und Leistung erforderlichen Weitergabe von Objekt- und Mieterkontaktdaten; Angebotsanfragen an Fachbetriebe über einen befristeten Link, Mieterkontaktdaten dort erst bei Beauftragung und nur auf ausdrückliche Auswahl;
- Freigabe-Links an vom Verantwortlichen benannte Empfänger (Bank, Makler): nur ausgewählte Dokumente, befristet, widerrufbar, nur mit Zugangscode; jeder Abruf wird mit Zeitpunkt und Dokument protokolliert (ohne IP-Adresse); Dateien, die der Empfänger zurückschickt, landen in einem Eingang des Verantwortlichen; der Empfänger kann außerdem bis zu drei Terminvorschläge machen oder um Rückruf bitten, die nur der Verantwortliche sieht;

- Vertrauensperson: Stammdaten einer vom Verantwortlichen benannten Person und ihrer Vollmacht (einschließlich Scan) für Bank-, Notar- und Darlehensangelegenheiten; die Person erhält keinen Zugang zur App;
- KI-gestützte Dokumentauswertung (z. B. Auslesen einer Nebenkostenabrechnung), nur wenn der Verantwortliche sie auslöst.

Eine Verarbeitung zu eigenen Zwecken des Betreibers findet nicht statt.

3. Art der Daten und Kategorien betroffener Personen

Datenarten:

- Stammdaten (Name, Anschrift, Kontaktdaten);
- Vertragsdaten des Mietverhältnisses (Mietbeginn/-ende, Miete, Kaution, Einheit);
- Abrechnungs- und Zahlungsdaten einschließlich Bankverbindung (letztere anwendungsseitig verschlüsselt);
- Verbrauchsdaten, einschließlich der vom Mieter selbst gemeldeten Zählerstände nebst Foto-Belegen;
- Anliegen- und Kommunikationsdaten: vom Mieter gemeldete Schäden, Fragen und Dokumentanfragen mit Freitext und Foto-/PDF-Anhängen; Nachrichten zwischen Verantwortlichem und Mieter; Daten zur Terminkoordination;
- Zustell- und Abrufdaten: Zeitpunkt der Zustellung eines Dokuments, seines Abrufs und der Lesebestätigung; Protokoll der Abrufe über Freigabe-Links (Zeitpunkt und Dokument);
- Dokumente, Belege und Übergabeprotokolle, einschließlich der über Freigabe-Links zurückgeschickten Dateien;
- Bewerbungsdaten von Mietinteressenten: selbst angegebene Angaben zu Beruf, Arbeitgeber, Netto-Einkommen, Bonität/SCHUFA, Haushaltsgröße, Haustieren/Rauchen, eine Freitext-Nachricht sowie eine elektronische Unterschrift;
- Auftrags- und Dienstleisterdaten: Aufträge an Service-Partner (Titel, Beschreibung, Tätigkeit, Objekt- und Vermietername, Termin, Betrag, Lohnanteil nach § 35a EStG), Fotos und Notizen zum Auftrag, Angebote, zugehörige Rechnungen sowie Kontaktdaten beauftragter Handwerks- und Dienstleistungsbetriebe;
- Daten einer Vertrauensperson: Name, Kontaktdaten, Art und Gültigkeit der Vollmacht, Vollmachts-Scan;
- E-Mail-Adressen von Empfängern eines Freigabe-Links (Bank-, Maklerkontakt) sowie deren Terminvorschläge oder Rückrufbitten (Zeitpunkte, Telefonnummer, optional Name, Ort und Notiz);
- Notizen des Verantwortlichen.

> Besondere Kategorien personenbezogener Daten (Art. 9 DSGVO) sind nicht Gegenstand der Verarbeitung; der Verantwortliche trägt dafür Sorge, keine solchen Daten in Freitext- oder Upload-Feldern einzugeben. Kontoauszüge, die der Verantwortliche zum Abgleich der Mieteingänge öffnet, werden nur im Browser gelesen und nicht an den Betreiber übertragen; gespeichert werden nur die daraus bestätigten Buchungen.

Betroffene Personen:

- Mieter und ehemalige Mieter des Verantwortlichen, die die App teilweise selbst nutzen (eigener, per Einladung erstellter Zugang);
- Mietinteressenten und Bewerber;
- weitere im Haushalt lebende oder im Mietverhältnis auftretende Personen (z. B. Mitbewohner, Bürgen);
- vom Verantwortlichen beauftragte Service-Partner (Hausmeister, Handwerks- und Dienstleistungsbetriebe) und deren Ansprechpartner;
- Ansprechpartner von Banken und Maklern bei Freigaben, Rückmeldungen, Rücksendungen und Terminabsprachen;
- vom Verantwortlichen benannte Vertrauenspersonen (Bevollmächtigte).

4. Weisungsbindung (Art. 28 Abs. 3 lit. a)

Der Betreiber verarbeitet die Daten ausschließlich auf dokumentierte Weisung des Verantwortlichen; Weisungen werden über die Funktionen der App erteilt (Anlegen, Ändern, Freigeben, Zustellen, Löschen). Auch Eingaben, die vom Verantwortlichen eingeladene Mieter, Mietinteressenten, Service-Partner oder Empfänger eines Freigabe-Links über die von ihm freigeschalteten Funktionen selbst vornehmen (z. B. Zählerstände, Anliegen, Bewerbungen, Auftragsnotizen, Rücksendungen), gelten als im Auftrag und auf Veranlassung des Verantwortlichen erfolgt. Hält der Betreiber eine Weisung für rechtswidrig, informiert er den Verantwortlichen unverzüglich. Eine Verarbeitung nach dem Recht der Union oder eines Mitgliedstaats bleibt vorbehalten; in diesem Fall wird der Verantwortliche vorab informiert, soweit rechtlich zulässig.

5. Vertraulichkeit (lit. b)

Zum Zugriff befugte Personen sind zur Vertraulichkeit verpflichtet. Der Betreiber greift auf Inhaltsdaten nur zu, soweit dies für Betrieb, Fehlerbehebung oder auf Wunsch des Verantwortlichen erforderlich ist.

6. Sicherheit der Verarbeitung (lit. c, Art. 32)

Der Betreiber trifft die in der Anlage TOM (unten) beschriebenen technischen und organisatorischen Maßnahmen und entwickelt sie entsprechend dem Stand der Technik fort.

7. Subauftragsverarbeiter (lit. d)

Der Verantwortliche erteilt die allgemeine Genehmigung zum Einsatz folgender Subauftragsverarbeiter:

- Supabase Inc. — Datenbank, Authentifizierung, Datei-Speicher; Datenhaltung in Frankfurt (AWS eu-central-1); DPA mit EU-Standardvertragsklauseln.
- Vercel Inc. (USA) — Hosting und Auslieferung der App; Laufzeit-Protokolle werden nach einem Tag gelöscht; DPA mit EU-Standardvertragsklauseln.

- Anthropic PBC (USA) — KI-Auswertung, nur bei aktiver Nutzung durch den Verantwortlichen; DPA mit EU-Standardvertragsklauseln; kein Modell-Training mit API-Daten.
- Brevo (Sendinblue SAS, Paris) — Versand der Einladungen ins Mieterportal und der Hinweis-E-Mails (Ziffer 2); Versanddaten in der EU; einzelne Unterauftragsverarbeiter von Brevo verarbeiten in den USA und in Indien, abgesichert über EU-Standardvertragsklauseln im Vertrag mit Brevo.

Über beabsichtigte Änderungen (Hinzufügen/Ersetzen) informiert der Betreiber vorab in der App oder per E-Mail; der Verantwortliche kann innerhalb von 14 Tagen aus wichtigem Grund widersprechen. Bei Widerspruch steht beiden Parteien die Kündigung des Nutzungsverhältnisses offen. Der Betreiber verpflichtet Subauftragsverarbeiter auf mindestens gleichwertige Datenschutzpflichten und haftet für sie wie für eigenes Handeln. Übermittlungen in Drittländer erfolgen nur mit Garantien nach Kap. V DSGVO (Standardvertragsklauseln bzw. Angemessenheitsbeschluss).

Externe Dienste ohne Zugriff auf Mieterdaten. Nutzt der Verantwortliche die Marktwert-Schätzung, übermittelt der Betreiber allein die Objektadresse an den Suchdienst Nominatim der OpenStreetMap Foundation (Vereinigtes Königreich, Angemessenheitsbeschluss), je Adresse einmal. Beim Import eines Online-Exposés per Link wird allein der Link an den Lesedienst der Jina AI GmbH (Berlin) übergeben. Namen, Mieterdaten oder Dokumente erhalten beide nicht.

Von Subauftragsverarbeitern zu unterscheiden sind Empfänger, an die der Verantwortliche über die App bewusst Daten weitergibt — etwa Banken und Makler über Freigabe-Links oder von ihm beauftragte Service-Partner und Fachbetriebe zur Auftrags-, Angebots- und Terminabwicklung. Diese Weitergabe erfolgt ausschließlich auf Veranlassung des Verantwortlichen; die Empfänger verarbeiten die Daten für ihre eigenen Zwecke in eigener datenschutzrechtlicher Verantwortung. Ebenfalls in eigener Verantwortung handeln Google (nur „Login mit Google“) und Paddle (Abrechnung eines MyImmo-Abos als Händler); beide erhalten keine Daten, die der Verantwortliche in der App über Dritte erfasst.

8. Unterstützung bei Betroffenenrechten (lit. e)

Der Betreiber unterstützt den Verantwortlichen mit geeigneten Mitteln bei der Beantwortung von Anträgen betroffener Personen (Art. 12–23 DSGVO) — insbesondere durch die Auskunfts-, Export-, Berichtigungs- und Löschfunktionen der App. Anträge, die beim Betreiber eingehen, leitet er unverzüglich an den Verantwortlichen weiter.

9. Meldepflichten und weitere Unterstützung (lit. f)

Der Betreiber meldet dem Verantwortlichen Verletzungen des Schutzes personenbezogener Daten unverzüglich nach Bekanntwerden mit den Informationen nach Art. 33 Abs. 3 DSGVO und unterstützt ihn bei seinen Pflichten aus Art. 32–36 DSGVO (Sicherheit, Meldungen, ggf. Datenschutz-Folgenabschätzung) unter Berücksichtigung der verfügbaren Informationen.

10. Löschung und Rückgabe (lit. g)

Nach Ende des Nutzungsverhältnisses — insbesondere bei Kontolöschung durch den Verantwortlichen — werden sämtliche personenbezogenen Daten einschließlich der gespeicherten Dateien (Belege, Dokumente, Fotos, Scans) unwiderruflich gelöscht, soweit keine gesetzliche Aufbewahrungspflicht des Betreibers entgegensteht. Der Verantwortliche kann seine Daten zuvor über die Export-Funktionen der App sichern. Restkopien in technischen Backups des Datenbank-Anbieters (tägliche Sicherung, Aufbewahrung 7 Tage) werden spätestens sieben Tage nach der Löschung automatisch überschrieben; sie dienen ausschließlich der Wiederherstellung im Störungsfall.

11. Nachweise und Kontrollen (lit. h)

Der Betreiber stellt dem Verantwortlichen alle zum Nachweis der Einhaltung dieses Vertrags erforderlichen Informationen zur Verfügung (insbesondere diese Vereinbarung, die Anlage TOM und die Zertifizierungen/DPAs der Subauftragsverarbeiter) und ermöglicht angemessene Überprüfungen. Kontrollen erfolgen in der Regel durch Auskünfte und Vorlage geeigneter Nachweise; Vor-Ort-Kontrollen nur bei konkretem Anlass und nach Ankündigung.

12. Schlussbestimmungen

Es gilt deutsches Recht. Die Haftung richtet sich nach Art. 82 DSGVO und den gesetzlichen Regeln. Sollten einzelne Bestimmungen unwirksam sein, bleibt der Vertrag im Übrigen wirksam. Bei Widersprüchen zu den allgemeinen Nutzungsbedingungen geht dieser AVV in Datenschutzfragen vor.

Anlage: Technische und organisatorische Maßnahmen (TOM)

- Zugangs- und Zugriffskontrolle: Anmeldung mit E-Mail/Passwort (bcrypt-Hash, Mindestlänge 8 Zeichen, bekannte geleakte Passwörter werden abgelehnt) oder Google-OAuth; optional Zwei-Faktor-Anmeldung (TOTP) mit Wiederherstellungscodes, von denen nur ein Hash gespeichert wird; vor besonders sensiblen Aktionen (Kontolöschung, Gesamtexport, Erstellen eines Freigabe-Links) wird eine frische Anmeldung verlangt; automatische Abmeldung nach Inaktivität (Standard 30 Minuten).
- Mandantentrennung: Row Level Security auf jeder Tabelle — jedes Konto liest und schreibt ausschließlich eigene Datensätze. Mieter lesen Objekt- und Vertragsdaten nur über begrenzte Ansichten mit den Feldern, die ihr Portal zeigt; Service-Partner sehen nur die ihnen zugewiesenen Aufträge und Objekte; Zugänge ehemaliger Mieter enden automatisch.
- Freigabe-Links: nur explizit ausgewählte Dokumente, befristet und widerrufbar; Inhalte erst nach Eingabe eines Zugangscodes, der nur als HMAC gespeichert wird; Sperre nach 10 Fehlversuchen; Abrufprotokoll ohne IP-Adresse.
- Dateien: Belege in einem privaten Datei-Speicher, abrufbar nur über signierte Links mit 60 Sekunden Gültigkeit; übrige Dateien in der Datenbank hinter Row Level Security. Ausgeliefert werden nur PDF und Bilder zur Ansicht, alles andere ausschließlich als Download.

- Endgeräte: Die als App installierbare Fassung legt auf dem Gerät über einen Service Worker nur eine Hinweisseite für den Fall ohne Internetverbindung ab; Seiten, Daten und Dateien aus dem Konto werden dabei nicht zwischengespeichert.
- Übertragungskontrolle: ausschließlich TLS-verschlüsselte Verbindungen; Content-Security-Policy und Sicherheits-Header. Hinweis-E-Mails enthalten keine Inhalte, nur den Hinweis auf Neues.
- Verschlüsselung: Speicherung bei Anbietern mit Verschlüsselung „at rest“; zusätzlich anwendungsseitige AES-256-GCM-Verschlüsselung von Bankverbindungsdaten mit Schlüssel außerhalb der Datenbank.
- Datensparsamkeit beim Missbrauchsschutz: Kennungen für Zugriffsbegrenzungen (IP-Adresse, E-Mail-Adresse) werden nur als HMAC gespeichert; Einträge, die älter als 24 Stunden sind, werden fortlaufend gelöscht.
- Verfügbarkeitskontrolle: Betrieb bei professionellen Cloud-Anbietern mit redundanter Infrastruktur; tägliche Datenbanksicherung mit 7 Tagen Aufbewahrung.
- Eingabekontrolle: Änderungen erfolgen kontogebunden über authentifizierte Sitzungen; destruktive Aktionen erfordern Bestätigung. Eingaben von Mietern, Mietinteressenten, Service-Partnern und Link-Empfängern sind dem Verantwortlichen zugeordnet und nur ihm zugänglich; Zustellungen und Abrufe werden mit Zeitpunkt festgehalten.
- Löschkonzept: Die Kontolöschung entfernt alle Datensätze und gespeicherten Dateien des Kontos; die Vollständigkeit wird bei jeder neuen Tabelle und jedem neuen Datei-Speicher durch automatische Tests geprüft.
- Organisatorisches: Zugriff auf Produktionssysteme nur durch den Betreiber; Geheimnisse (API-Schlüssel, Verschlüsselungsschlüssel) werden außerhalb des Quellcodes in der Hosting-Umgebung verwaltet.

Unterzeichnung

In der App wird dieser Vertrag mit der Registrierung bzw. der weiteren Nutzung wirksam. Für die schriftliche Vorlage:

Verantwortlicher (Vermieter)

Ort, Datum

Name / Unterschrift

Auftragsverarbeiter (MyImmo)

Ort, Datum

Jonas Scharp